

運用 CSA AI Control Matrix 建立可信任的 AI 防線

蔡一郎

蔡一郎 Steven Tsai

以策略與專業，推動資安產業發展與人才培育，
共築更安全的數位未來。



學歷

- 國立成功大學 電腦與通信工程研究所 博士候選人
- 國立成功大學 電機工程研究所 碩士
- 國立成功大學 EMBA 碩士班



現任

- ✓ 來鈞數位科技股份有限公司 全球資安長暨台灣區總經理
- ✓ 博暉顧問股份有限公司 創辦人
- ✓ 台灣數位安全聯盟 榮譽理事長
- ✓ 台灣網際空間與安全策略發展協會 理事長
- ✓ 台灣資安大聯盟 副會長
- ✓ 多個國際資安組織與專業社群領導職務 (InfoSec Taiwan / OWASP / HoneyNet / Cloud Security Alliance / CSCIS...等)
- ✓ 政府部會資安稽核委員
- ✓ 自由作家：資訊圖書著作 37 本、技術專欄文章 100+ 篇
- ✓ 部落格：<https://blog.yilang.org>



曾任

- ✓ 微智安聯股份有限公司 創辦人兼執行長
- ✓ 財團法人國家實驗研究院國家高速網路與計算中心 研究員
- ✓ 台灣數位安全聯盟 理事長
- ✓ 中華民國資料保護協會 監事
- ✓ 中華民國資訊安全學會 常務監事
- ✓ 數位經濟暨產業發展協會 理事
- ✓ 台灣資訊安全聯合發展協會 監事
- ✓ 中華民國人壽保險商業同業公會 資安顧問 / 資安工作小組委員



專業證照

RHCE · CCNA · CCAI · CEH · CHFI · ACIA · ITIL Foundation · ISO 27001 LA
ISO 20000 LAC · BS10012 · LAC · ISO 17065 · ISO 42001 LA · CSA STAR Auditing
CCSK · CMMC Essential · CSM · CSPO



“

以策略與專業，
推動資安產業發展與
人才培育，
共築更安全的
數位未來。

”

Steven Tsai



讓 CSA AICM 與台灣接軌



- 完成問卷者 TWCSA 提供 7-11 禮物卡 50 元！
- (提供完成問券的畫面即可)

認識雲端安全聯盟 Cloud Security Alliance

The screenshot shows the CSA website header with navigation links: CSAI, CHAPTERS, EVENTS, BLOG, ACCOUNT, and SIGN OUT. Below the header is a blue banner with the CSA logo and a navigation menu: Membership, STAR Program, Education, Research, and Strategic Initiatives. A search icon is also present. Below the banner is a blue bar with the text: "Learn why hybrid environments are now the norm and how to build a security architecture that embraces this. Register for the July 1st webinar →". The main content area features a large image of a woman with glasses working on a laptop. Overlaid on the image is the text: "Trusted AI Safety Expert (TAISE) Certificate". Below this text is a button that says "Download the Prep-Kit". At the bottom of the image, there are two award badges: "2026 Silver Globee Winner" and "Winner of the 2026 SC Awards". The Taise logo is prominently displayed, with the tagline "Trusted AI Safety Expert" below it. A small "支援" (Support) button is visible in the bottom right corner of the image area.

CSA cloud security alliance®

Membership ▾ STAR Program ▾ Education ▾ Research ▾ Strategic Initiatives ▾

Learn why hybrid environments are now the norm and how to build a security architecture that embraces this. Register for the July 1st webinar →

Trusted AI Safety Expert (TAISE) Certificate

Now Available: The Industry's First Credential for Trustworthy AI.

Download the Prep-Kit

2026 Silver Globee Winner

Winner of the 2026 SC Awards

TAISE™
Trusted AI Safety Expert

支援

雲端安全聯盟 (CSA) 是全球領先的非營利組織，致力於提高人們對人工智慧、雲端運算和零信任等前瞻性網路安全主題的認識、實施和認證。

- CSA的使命與全球角色
- 企業參與計劃
- 研究和工作小組倡議
- 產業領導力專案和策略舉措
- 雲端安全保障工具和框架 (包括 STAR、STAR for AI 和 Valid-AI-ted)
- 教育、培訓和專業認證 (CCSK、CCZT、TAISE)
- 社區項目，包括分會和活動
- 組織里程碑、行業認可和影響

<https://cloudsecurityalliance.org/>

為什麼需要 AICM

核心價值與基礎



全球首個供應商中立的 AI 治理框架

協助編碼評估 AI 風險，並與 ISO 42001 及 NIST 等國標標準保持一致。



基於 CCM v4.1 的極極基礎

結合營運控制矩陣的成熟原則，提供可衡量且見於理解的安全成效。



專家驅動與共識導向

由 AI 控制工作小組與產業專家共同開發，確保框架的專業性與實用性。



框架結構與五大維度



國際標準對齊與資源

ISO 42001



✓ 已發布映射射處

NIST AI 600-1 (2024)



✓ 已發布映射射處

歐盟 AI 法案 (EU AI Act)



→ 進行中 (即將發布)



cloudsecurityalliance.org/aicm



18 個安全領域與 243 個控制目標

涵蓋從身份存取管理 (IAM) 到迴型安全 (MDS) 的完整 AI 生命週期。



五大評估維度

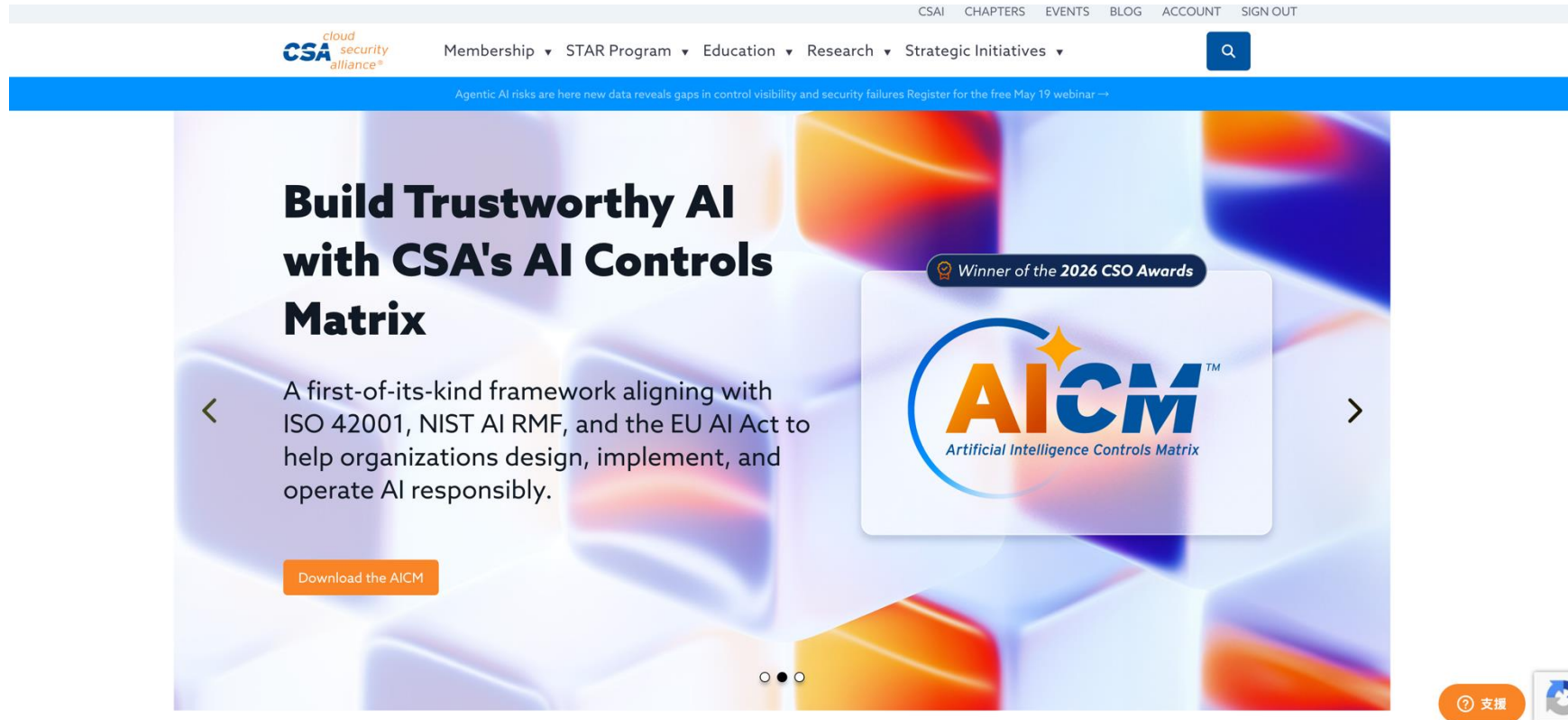
包含控制類型、所有權、架構權制性、生命週期及成熟度。



完整的 AICM 資源包

包含控制圖型、AI-CAIQ 問卷、實計指南及國際標準對應表。

Cloud Security Alliance AI Controls Matrix (AICM)



人工智慧控制矩陣 (AICM) 是首個面向雲端人工智慧系統的、與供應商無關的框架，組織可以利用 AICM 以安全負責的方式開發、部署和營運人工智慧技術。AICM 由產業專家開發，基於 CSA 的雲端控制矩陣 (CCM)，並融合了最新的人工智慧安全最佳實踐。

<https://cloudsecurityalliance.org/artifacts/ai-controls-matrix>

AI Control Matrix v1.1

A&A	Audit & Assurance	IAM	Identity & Access Management
AIS	Application & Interface Security	IPY	Interoperability & Portability
BCR	Business Continuity Mgmt & Op Resilience	I&S	Infrastructure Security
CCC	Change Control & Configuration Management	LOG	Logging & Monitoring
CEK	Cryptography, Encryption & Key Management	MDS	Model Security
DCS	Datacenter Security	SEF	Sec. Incident Mgmt, E-Disc & Cloud Forensics
DSP	Data Security & Privacy	STA	Supply Chain Mgmt, Transparency & Accountability
GRC	Governance, Risk Management & Compliance	TVM	Threat & Vulnerability Management
HRS	Human Resources Security	UEM	Universal EndPoint Management

18 Security Domains, Containing 247 Control Objectives

AICM 對應框架

UPDATED

ISO/IEC 42001:2023

AI Management System standard for organizational AI governance

NEW

AIUC-1

AI agent security, safety and reliability standard that covers enterprise risk

UPDATED

NEW

NIST AI 600-1 & AI RMF

Combined Generative AI and AI Risk Management Framework alignment

UPDATED

EU AI Act

European Union AI regulation compliance mapping

UPDATED

BSI AIC4

German Federal Office Criteria Catalogue for AI Cloud Services (AIC4)

SYNCED

CCM v4.1

Synchronized with the Cloud Controls Matrix (CCM) for a unified cloud+AI governance

AICM v1.1 Comparison & Mapping to ISO 42001

Key insight: AICM serves as an implementation bridge for ISO 42001. Organizations pursuing ISO 42001 certification can use AICM's 247 controls as actionable guidance.

How They Compare

- **ISO 42001** = Management System Standard
Defines **WHAT organizations** must achieve
- **AICM** = Control Implementation Framework
Specifies **HOW** to operationalize requirements

Mapping Coverage

194 of 247 AICM controls mapped to ISO 42001 clauses & Annex A

- No Gap (145) - 59%
- Partial Gap (97) - 39%
- Full Gap (5) - 2%

Where AICM Extends Beyond ISO 42001

Full Gap Controls (AICM-unique):

- CEK-21: Key Inventory Management
- DCS-17: Data Center Metrics
- DCS-18: Datacenter Operations Resilience
- LOG-08: Audit Logs Sanitization
- SEF-06: Event Triage Processes

Partial Gap Areas (AICM adds specificity):

- Secure application development lifecycle
- Application security testing criteria
- Risk-triggered audit requirements
- Baseline security

AICM v1.1 Comparison & Mapping to NIST AI RMF & AI 600-1

Key insight: NIST AI RMF and AI 600-1 are risk frameworks, not control catalogs. The high Full Gap (45%) is expected because NIST intentionally delegates infrastructure security to companion frameworks like NIST SP 800-53. AICM bridges this gap with actionable controls.

How They Compare

- **NIST AI RMF & AI 600-1** = Risk Frameworks Focus on AI lifecycle governance, risk management, and GenAI-specific guidance

vs.

- **AICM** = Security Controls Framework
Provides technical implementation beyond regulatory requirements

Mapping Coverage

All 247 AICM controls mapped to NIST AI RMF & AI 600-1

- No Gap (18) - 7%
- Partial Gap (119) - 48%
- Full Gap (110) - 45%

Where AICM Extends Beyond the NIST AI RM & AI 600-1

110 Full Gap Controls including:

- All Datacenter Security (DCS) controls
- Physical infrastructure security
- Key Management lifecycle (CEK)
- Interoperability & Portability (IPY)
- Business Continuity (BCR)

Why the large gap?

NIST AI frameworks focus on AI-specific risk governance – not infrastructure security. Traditional IT controls are expected via NIST SP 800-53, etc.

AICM v1.1 Comparison & Mapping to EU AI Act

Key insight: EU AI Act compliance requires more than regulatory alignment. AICM provides the security foundation, datacenter, encryption, endpoint, and operational controls, that organizations need to securely deploy and operate AI systems that meet EU AI Act requirements.

How They Compare

- **EU AI Act** = Legal Regulation
Defines compliance obligations for high-risk AI

vs.

- **AICM** = Security Controls Framework
Provides technical implementation beyond regulatory requirements

Mapping Coverage

All 247 AICM controls mapped to 39 EU AI Act Articles + 5 Annexes

- No Gap (50) - 20%
- Partial Gap (112) - 45%
- Full Gap (85) - 34%

Where AICM Extends Beyond the EU AI Act

85 Full Gap Controls (AICM-unique), including:

- All Datacenter Security (DCS) controls
- Key Management lifecycle (CEK)
- Human Resources security (HRS)
- Endpoint Management (UEM)
- Change Control & Config Mgmt (CCC)

WHY the large gap:

EU AI Act focuses ONLY on AI-specific obligations (transparency, risk assessment, human oversight) and no infrastructure security.
AICM fills this operational security gap requirements.

AICM v1.1 Comparison & Mapping to the German BSI AIC4.

Key insight: BSI AIC4 and AICM share a common architectural foundation: cloud security controls extended for AI. Organizations certified against BSI AIC4 (or C5) will find AICM highly complementary, with 99% coverage and minimal additional control implementation required.

How They Compare

- **BSI AIC4** = German AI Cloud Security Catalog
Security criteria for AI cloud services, aligned with C5 cloud security standard

vs.

- **AICM** = Security Controls Framework
Provides technical implementation beyond regulatory requirements

Mapping Coverage

All 247 AICM controls mapped to BSI AIC4

- No Gap (210) - 85%
- Partial Gap (34) - 14 %
- Full Gap (3) -1%

Where AICM Extends Beyond the BSI AIC4

Why such high alignment?

- Both are security control frameworks
- Both target cloud-based AI systems
- BSI AIC4 builds on C5 (cloud security)
- AICM builds on CCM v4.1 (cloud security)

Only 3 Full Gap Controls (AICM-unique), including:

- AIS-08: API Security
- DSP-08: Data Privacy by Design and Default
- HRS-03: Clean Desk Policy and Procedures

Gaps in implementation specificity, not scope

Framework Mapping Summary

AICM v1.1 Alignment Across Major AI Governance Frameworks**

Framework	No Gap	Partial Gap	Full Gap	Alignment with AICM
BSI AIC4	210 (85%)	34 (14%)	3 (1%)	★★★★★ Highest
ISO/IEC 42001: 2023	145 (59%)	97 (39%)	5 (2%)	★★★★ High
EU AI Act	50 (20%)	112 (45%)	85 (34%)	★★★ Moderate
NIST AI RMF & AI 600-1	18 (7%)	119 (48%)	110 (45%)	★★ Lower

Visual Comparison: No Gap Coverage



**** Security control frameworks (BSI AIC4, ISO 42001) show high alignment. Risk/regulatory frameworks (EU AI Act, NIST) show expected gaps – AICM provides the implementation controls they intentionally omit.**

AI Control Matrix

- 控制類型 (Control Type)
 - AI 專屬 (AI-specific)
 - AI 與雲端相關 (AI & Cloud-related)
 - 雲端專屬 (Cloud-specific)
- 控制適用性與所有權 (Control Applicability and Ownership)
 - 責任歸屬：參與者之間 6 種不同的控制實作責任
 - 4 層生成式 AI/LLM 服務交付模型：
 - 生成式 AI 營運 (genAI Ops)
 - 模型層 (The Model)
 - 編排服務層 (The Orch. Service)
 - 生成式 AI 應用層 (The Gen/AI Application)



AI Control Matrix

- 架構關聯性 – 生成式 AI 堆疊組件 (Architectural Relevance – GenAI Stack Components)
 - 物理層 (Physical)
 - 網路層 (Network)
 - 運算層 (Compute)
 - 儲存層 (Storage)
 - 應用層 (Application)
 - 數據層 (Data)
- 生命週期關聯性 (Lifecycle Relevance)
 - LLM 生命週期階段：
 - 準備階段 (Preparation)
 - 開發階段 (Development)
 - 評估與驗證 (Evaluation/Validation)
 - 部署階段 (Deployment)
 - 交付階段 (Delivery)
 - 服務退役 (Service Retirement)



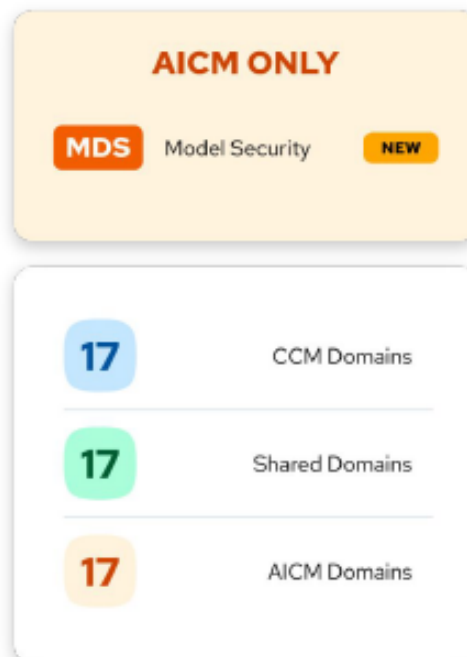
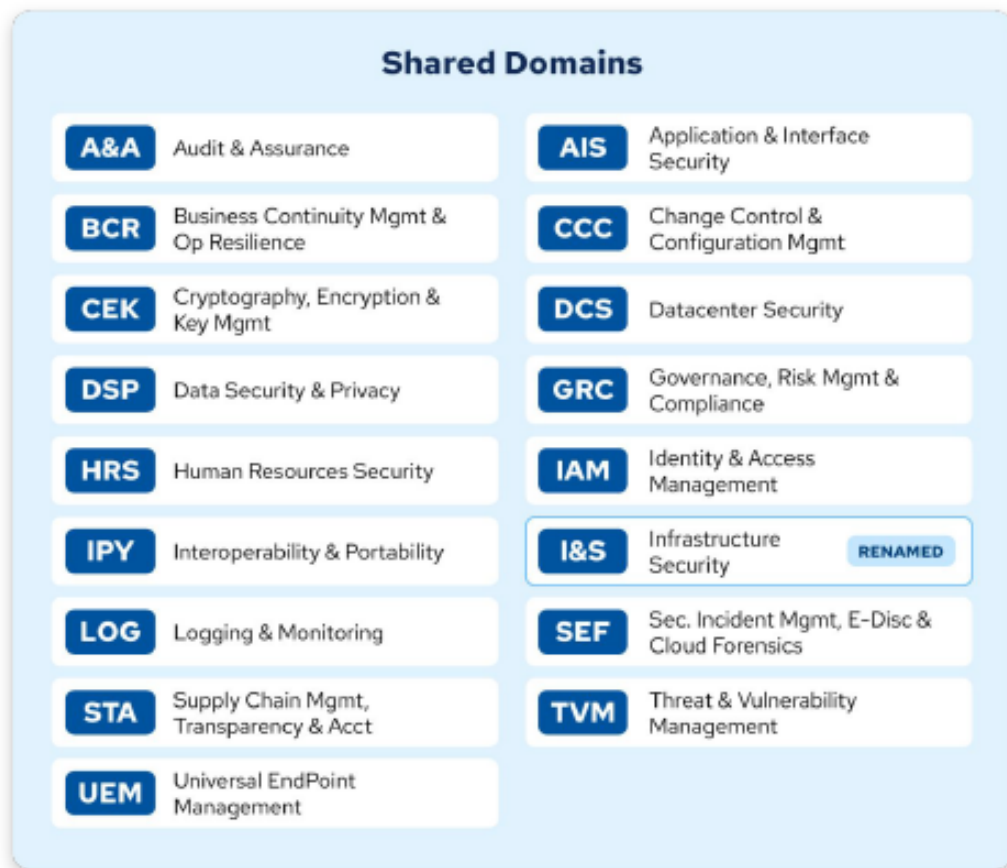
AI Control Matrix

- 威脅類別 (Threat Category)
 - 模型操控 (Model manipulation)
 - 數據投毒 (Data poisoning)
 - 敏感數據洩漏 (Sensitive data disclosure)
 - 模型竊取 (Model theft)
 - 模型/服務故障或功能異常 (Model/Service failure/Malfunctioning)
 - 不安全的供應鏈 (Insecure supply chains)
 - 不安全的應用程式/外掛程式 (Insecure apps/plugins)
 - 阻斷服務攻擊 (Denial of Service, DoS)
 - 治理或合規性喪失 (Loss of governance/compliance)



AICM and CCM Relation

AICM: Superset of CCM



- Shared domain (CCM + AICM)
- AICM-only new domain



Key Differences

IVS → I&S (Renamed): CCM's "Infrastructure & Virtualization Security" (IVS) domain is renamed "Infrastructure Security" (I&S) in AICM – the scope and controls are otherwise the same.

MDS (New): AICM introduces "Model Security" as an entirely new domain specific to AI/ML model protection, addressing threats amplified by generative AI systems such as model poisoning, prompt injection, and unauthorized model access.

AICM v1.0- 2025 to AICM v1.1-2026: What's Changed

AICM v1.0

243

controls across 18 domains

Includes

- Control Matrix with Relevance & Applicability
- AI Consensus Assessment Initiative Questionnaire (AI-CAIQ)
- Mapping to BSI AIC4 Catalog
- Mapping to NIST AI 600-1 (2024)
- Mapping to ISO 42001
- Mapping to EU AI Act
- Auditing Guidelines
- Implementation Guidelines

AICM v1.1 – Changes

247

controls across all v1.0 content, plus enhancements

DCS – Datacenter Security

+3 controls

DCS-01

DCS-17

DCS-18

IAM – Identity & Access Management

-1 controls

IAM-12

LOG – Logging & Monitoring

+1 control

LOG-08

SEF – Security Incident Management

+1 control

SEF-09

DCS – Datacenter Security

+3 controls

Mapping to AIUC-1 (2 directional)

Summary

v1.0 to v1.1

what changed

+5

Net increase of 5 controls
243 → 247



New bidirectional mapping to AIUC-1

+3

Stronger DCS coverage – DCS-01, DCS-17, DCS-18

-1

IAM-12 Safeguard Logs Integrity removed

+1

LOG-08 Audit Logs Sanitization added

+1

SEF-09 Incident Records Management added

Strategic AICM Implementation

A CISO's Roadmap to Trustworthy AI Governance

1	ASSESS	2	INTEGRATE	3	CERTIFY	4	SCALE
	• AI system inventory • AI-CAIQ self-assessment • Governance maturity • Gap analysis		• Supply chain controls • Vendor assessment • Contract requirements • Procurement process		• STAR for AI Level 1 (self-assessment) • STAR for AI Level 2 (third-party audit)		• AI Governance CoE • Compliance automation • SOC integration • Continuous monitoring

Implementation Timeline

Immediate	Short-Term	Medium-Term	Long-Term
• Executive briefing • AI inventory • Download AICM • Assemble team	• Complete AI-CAIQ • Develop roadmap • Begin vendor assessment • Establish governance	• Implement controls • GRC integration • STAR Level 1 • AI security ops	• STAR Level 2 • AI Governance CoE • Business acceleration • Industry leadership

控制責任的利害關係人

- 基礎設施與營運供應商（ Gen AI Ops/Processing Infra - CSP ）這涉及支撐 AI 運算與處理的底層雲端基礎設施，在此層級中，安全控制的實施與合規責任通常由**雲端服務供應商（ CSP ）與模型供應商（ MP ）共同承擔（ Shared CSP-MP ）。
- 模型供應商（ The Model - MP ）這專指 AI 模型本身的開發、訓練與安全防護。與模型直接相關的控制措施，其責任完全歸屬於模型供應商（ Owned by MP ）。
- 服務編排供應商（ Orchestrated Services - OSP ）這涵蓋了將 AI 模型與其他服務進行整合、部署的流程，例如 MLOps 訓練管道（ training pipeline ）等。此層級的安全控制責任由服務編排供應商（ Owned by OSP ）負責。
- 應用程式供應商（ GenAI Apps - AP ）這包含了最終提供給終端使用者操作的應用程式，無論是企業自行開發的內部應用，或是以軟體即服務（ SaaS ）形式提供的應用程式。確保應用程式安全與存取控制的責任，歸屬於應用程式供應商（ Owned by AP ）

AICM 評估

AI CONTROLS MATRIX v1.0.3					Typical Control Applicability and Ownership										Architectural Relevance - AI Stack Components						Lifecycle Relevance						
Control Domain	Control Title	Control ID	Control Specification	Control Type	Gen AI OPS/Processing Infrastructure (PI)	Model	Orchestrated Services	Application	Phys	Network	Compute	Storage	App	Data	Preparation	Development	Evaluation/Validation	Deployment	Delivery	Service Retirement	Model manipulation						
Audit & Assurance - AAA																											
Audit & Assurance	Audit and Assurance Policy and Procedures	AAA-01	Establish, document, approve, communicate, apply, evaluate and maintain audit and assurance policies and procedures and standards. Review and update the policies and procedures at least annually or upon significant changes.	Cloud & AI Related	Shared across the supply chain	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	TRUE	TRUE	TRUE	TRUE	TRUE	TRUE	Data collection, Data curation, Data storage	Design, Guardrails, Training	Evaluation, Validation/Red Teaming, Re-evaluation	AI Services supply chain	Continuous improvement	Data deletion, Archiving, Model disposal	TRUE						
Audit & Assurance	Independent Assessments	AAA-02	Conduct independent audit and assurance assessments according to relevant standards at least annually.	Cloud & AI Related	Shared across the supply chain	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	TRUE	TRUE	TRUE	TRUE	TRUE	TRUE	Data collection, Data curation, Data storage	Design, Training, Guardrails	Evaluation, Validation/Red Teaming, Re-evaluation	AI Services supply chain, AI applications, Orchestration	Continuous monitoring, Continuous improvement, Operations, Maintenance	Data deletion, Model disposal, Archiving	TRUE						
Audit & Assurance	Risk Based Planning Assessment	AAA-03	Perform independent audit and assurance assessments in response to significant changes or emerging risks and according to risk-based plans and policies.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	TRUE	TRUE	TRUE	TRUE	TRUE	TRUE	Data collection, Data curation, Data storage	Design, Training, Guardrails	Evaluation, Validation/Red Teaming, Re-evaluation	AI Services supply chain, AI applications	Continuous improvement	Archiving, Data deletion, Model disposal	TRUE						
Audit & Assurance	Requirements Compliance	AAA-04	Verify compliance with all relevant standards, regulations, legislative/contractual and statutory requirements applicable to the audit.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	TRUE	TRUE	TRUE	TRUE	TRUE	TRUE	Data collection, Data curation, Data storage	Design, Training, Guardrails	Evaluation, Validation/Red Teaming, Re-evaluation	AI Services supply chain, AI applications	Operations, Maintenance, Continuous improvement	Archiving, Data deletion, Model disposal	TRUE						
Audit & Assurance	Audit Management Process	AAA-05	Define and implement an Audit Management process aligned with global auditing standards, to support audit planning, risk analysis, security control assessment, conclusion, remediation schedules, report generation, and review of past reports and supporting evidence.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	TRUE	TRUE	TRUE	TRUE	TRUE	TRUE	N/A	Guardrails	Evaluation, Validation/Red Teaming, Re-evaluation	AI Services supply chain, AI applications	Continuous improvement, Operations, Maintenance, Continuous monitoring	Archiving, Data deletion, Model disposal	TRUE						
Audit & Assurance	Remediation	AAA-06	Establish, document, approve, communicate, apply, evaluate and maintain a risk-based corrective action plan to remediate audit findings, regularly review and report remediation status to relevant stakeholders.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	TRUE	TRUE	TRUE	TRUE	TRUE	TRUE	N/A	Design, Training, Guardrails	Re-evaluation, Validation/Red Teaming, Evaluation	AI applications, AI Services supply chain	Continuous improvement	Model disposal, Data deletion, Archiving	TRUE						
Application & Interface Security - AIS																											
Application & Interface Security	Application and Interface Security Policy and Procedures	AIS-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for application security. Review and update the policies and procedures at least annually or after significant system changes.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Shared Orchestrated Service Provider-Application Provider (Shared OSP-AP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Data collection, Data curation, Data storage	Training, Design, Guardrails	Evaluation, Validation/Red Teaming, Re-evaluation	AI Services supply chain, AI applications, Orchestration	Continuous monitoring, Continuous improvement, Maintenance, Operations	Archiving, Model disposal, Data deletion	FALSE						
Application & Interface Security	Application Security Baseline Requirements	AIS-02	Establish, document and maintain baseline requirements for securing applications?	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Shared Orchestrated Service Provider-Application Provider (Shared OSP-AP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Data storage, Data curation, Data collection	Design, Guardrails, Supply Chain, Training	Validation/Red Teaming, Evaluation, Re-evaluation	AI Services supply chain, AI applications	Continuous monitoring, Continuous improvement, Maintenance, Operations	Archiving	TRUE						
Application & Interface Security	Application Security Metrics	AIS-03	Define and implement technical and operational metrics in alignment with business objectives, security requirements, and compliance obligations.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Shared Orchestrated Service Provider-Application Provider (Shared OSP-AP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Resource provisioning	Guardrails, Design	Validation/Red Teaming, Evaluation, Re-evaluation	AI applications, AI Services supply chain	Continuous monitoring, Continuous improvement, Operations	Archiving	FALSE						
Application & Interface Security	Secure Application Development Lifecycle	AIS-04	Define and implement a secure software development lifecycle (SDLC) process for application requirements analysis, planning, design, development, testing, deployment, and operation in accordance with security requirements defined by the organization.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Owned by the Orchestrated Service Provider (OSP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Resource provisioning, Team and expertise	Guardrails, Supply Chain, Design	Validation/Red Teaming, Evaluation, Re-evaluation	AI applications, AI Services supply chain, Orchestration	Continuous monitoring, Continuous improvement, Operations, Maintenance	Archiving	TRUE						
Application & Interface Security	Application Security Testing	AIS-05	Implement a testing strategy, including criteria for acceptance of new information systems, upgrades and new versions, which provides application security assurance and maintains compliance while meeting organizational delivery goals. Automate when applicable and possible.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Shared Model Provider-Orchestrated Service Provider (Shared MP-OSP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Resource provisioning, Team and expertise	Guardrails, Training, Supply Chain	Validation/Red Teaming, Re-evaluation	AI applications, AI Services supply chain	Continuous improvement, Operations, Maintenance	N/A	TRUE						
Application & Interface Security	Secure Application Deployment	AIS-06	Establish and implement strategies and capabilities for secure, standardized, and complete application deployment. Automate where possible.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Shared Model Provider-Orchestrated Service Provider (Shared MP-OSP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Resource provisioning, Team and expertise	Guardrails, Design	Validation/Red Teaming	AI applications, Orchestration	Maintenance, Continuous improvement, Operations, Continuous monitoring	N/A	TRUE						
Application & Interface Security	Application Vulnerability Remediation	AIS-07	Define and implement a process to remediate application security vulnerabilities, automating remediation when possible.	Cloud & AI Related	Shared Cloud Service Provider-Model Provider (Shared CSP-MP)	Owned by the Model Provider (MP)	Shared Orchestrated Service Provider-Application Provider (Shared OSP-AP)	Owned by the Application Provider (AP)	FALSE	TRUE	TRUE	TRUE	TRUE	TRUE	Resource provisioning, Team and expertise	Guardrails, Supply Chain, Design	Validation/Red Teaming	AI applications, AI Services supply chain, Orchestration	Continuous improvement, Maintenance	N/A							

Q & A

